

보안 정책 가이드

1. 비밀번호 정책

모든 임직원은 다음 비밀번호 규칙을 준수해야 합니다.

- 최소 12자 이상 (영문 대소문자 + 숫자 + 특수문자 조합)
- 90일마다 변경 필수
- 최근 5개 비밀번호 재사용 금지
- 3회 연속 로그인 실패 시 계정 잠금 (30분)
- 잠금 해제: IT 헬프데스크 (내선 1234) 또는 셀프서비스 포털

2. 정보 분류 체계

사내 정보는 4단계로 분류됩니다.

기밀 (Confidential): 경영 전략, M&A 정보, 미공개 재무 데이터

- 접근: C레벨 + 지정된 담당자만
- 저장: 암호화 필수 (AES-256)
- 전송: 사내 보안 메일만 허용
- 출력: 금지

대외비 (Internal Only): 인사 정보, 급여 데이터, 고객 개인정보

- 접근: 업무상 필요한 부서원
- 저장: 사내 서버만 (클라우드 저장 시 DLP 승인 필요)
- 전송: 사내 메일 또는 승인된 협업 도구
- 출력: 부서장 승인 필요

일반 (General): 사내 공지사항, 업무 매뉴얼, 교육 자료

- 접근: 전 임직원
- 저장: 제한 없음
- 전송: 제한 없음
- 출력: 자유

공개 (Public): 회사 소개서, 채용 공고, 보도자료

- 접근: 누구나
- 저장/전송/출력: 제한 없음

3. 물리적 보안

- 사무실 출입: 사원증 RF 카드 + 지문 인식 (2단계 인증)
- 서버실 출입: RF 카드 + 지문 + PIN 번호 (3단계 인증)
- 방문객: 안내데스크에서 임시 출입증 발급, 직원 동행 필수
- CCTV: 사무실 공용 공간 24시간 녹화, 30일 보관
- 분실물: 사원증 분실 시 즉시 IT 헬프데스크에 신고 (내선 1234)

4. 개인정보 처리

- 고객 개인정보 수집 시 반드시 동의서 확보
- 개인정보 보유 기간: 수집 목적 달성 후 즉시 파기 (법적 보관 의무 제외)
- 개인정보 접근 로그: 6개월 보관
- 개인정보 유출 사고 발생 시: 24시간 이내 개인정보보호 책임자(DPO)에게 보고
- DPO 연락처: privacy@company.com / 내선 5678

5. 소프트웨어 사용

- 업무용 PC에 미인가 소프트웨어 설치 금지
- 소프트웨어 설치 요청: IT 헬프데스크 티켓 발행
- 라이선스 관리: IT팀에서 중앙 관리 (개인 구매 후 비용 청구 불가)
- 오픈소스 사용: 법무팀 라이선스 검토 필수 (GPL, AGPL 주의)
- 생성형 AI 도구: 보안팀 승인 후 사용 가능 (기밀/대외비 데이터 입력 금지)

6. 사고 대응 절차

보안 사고 발생 시 다음 절차를 따릅니다:

- 1단계: 사고 인지 즉시 보안팀에 보고 (security@company.com / 내선 9999)
- 2단계: 보안팀 초기 분석 (1시간 이내)
- 3단계: 영향 범위 파악 + 임시 조치 (4시간 이내)
- 4단계: 경영진 보고 (심각도 P1/P2인 경우 즉시)
- 5단계: 원인 분석 + 재발 방지 대책 (7일 이내)
- 6단계: 사후 보고서 작성 + 전사 공유 (14일 이내)

위반 시 징계: 경고 ~ 해고 (보안 규정 위반 심각도에 따라 인사위원회 결정)